

API Testing Log

Target: DVWA API

Tools Used

- Burp Suite
- Postman
- sqlmap

Test Log

Test ID	Vulnerability	Severity	Target Endpoint
008	BOLA	Critical	/api/users
009	GraphQL Injection	High	/graphql
010	SQL Injection	High	/api/login
011	Broken Auth Token	Critical	/api/profile

2. Manual Testing (Burp Suite)

Objective: Unauthorized Access via Token Manipulation

Steps Performed:

1. Intercepted API request in Burp
2. Captured Authorization header:

Authorization: Bearer user_token_123

3. Replaced with another user/admin token
4. Modified user ID in request:

GET /api/users/124

Result:

- Accessed other users' data without authorization
 - Confirmed **Broken Object Level Authorization (BOLA)**
-

API Security Testing Checklist

Enumeration

- Identify all API endpoints (/api/v1/, /admin/, /graphql)
 - Analyze JavaScript files for hidden endpoints
 - Map request/response structure
-

Authorization Testing

- Test for BOLA using Burp Suite
 - Modify object IDs (e.g., user_id)
 - Check access across different roles
-

Authentication Testing

- Test weak or reusable tokens
 - Check token expiration
 - Attempt token reuse across sessions
-

Injection Testing

- Run sqlmap on endpoints
 - Test payloads manually (SQL/NoSQL)
-

GraphQL Testing

- Fuzz queries using Postman
 - Request excessive data fields
 - Test introspection queries
-

4. Summary

Conducted API security testing on DVWA, identifying critical vulnerabilities including Broken Object Level Authorization, GraphQL injection, and SQL injection. Exploited weak

authentication and improper access controls using Burp Suite and Postman. Demonstrated unauthorized data access and injection flaws, highlighting significant risks to data confidentiality and application security.